

WEEK 5 ASSIGNMENT

VAPT Tools - Practical Learning

CYBERSECURITY INTERNSHIP

Submitted By	Akash Sanuria
Intern ID	DG/SEPTEMBER/CYBER/171
Internship	Cybersecurity Internship
Week	Week 5 Assignment
Submission Date	07 October 2026

DG Interns Hub

1. Introduction to VAPT

Vulnerability Assessment and Penetration Testing (VAPT) is a structured security-testing approach used to discover weaknesses, understand exposure, and validate security controls in authorized environments. Vulnerability assessment focuses on identifying and prioritizing weaknesses, while penetration testing validates how those weaknesses could affect a system under controlled conditions.

The objective of this Week 5 practical was to learn basic VAPT tooling by using Nmap for network scanning, Nikto for web-server assessment, and Burp Suite for HTTP request interception. All testing in this assignment was limited to the internship-provided authorized target, testphp.vulnweb.com.

1.1 Objectives

- Run Nmap SYN, service/version, and aggressive scans and interpret the results.
- Attempt a Nikto web vulnerability scan and record the actual outcome.
- Configure Burp Suite as an intercepting proxy and capture multiple HTTP requests.
- Document findings without inventing vulnerabilities that were not observed.
- Understand how connectivity, filtering, headers, and proxy interception affect VAPT work.

1.2 Tools Used

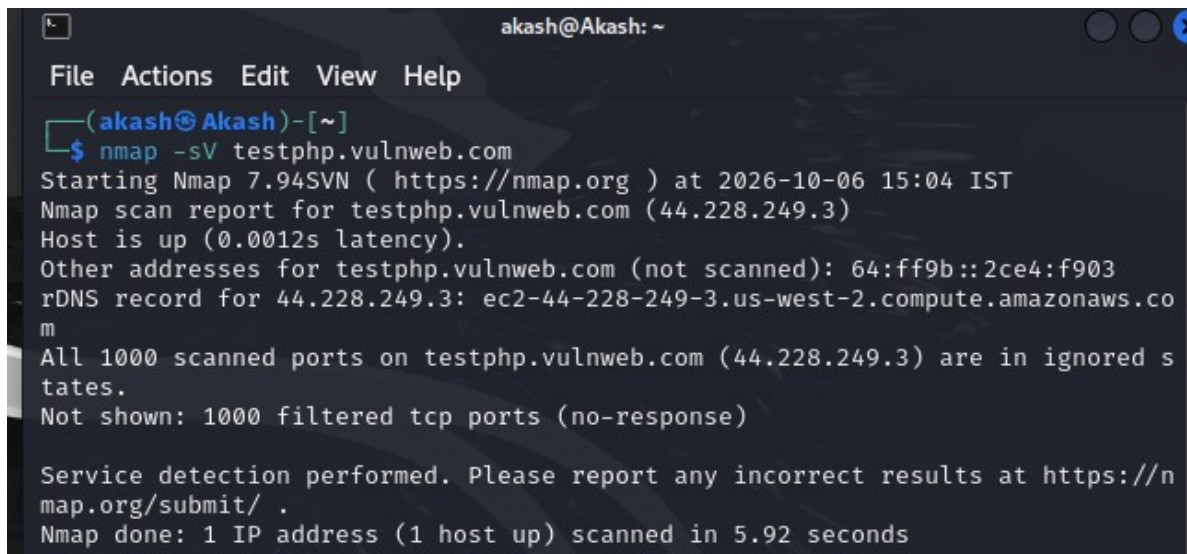
Tool	Purpose	Environment
Nmap	Port, service and host discovery	Kali Linux
Nikto	Web server vulnerability scanning	Kali Linux
Burp Suite Community	HTTP proxy and request inspection	Kali Linux
cURL / Netcat	Connectivity troubleshooting	Kali Linux

2. Nmap - Network Scanning

Nmap was used against the authorized test host to examine port reachability and attempt service and operating-system detection.

2.1 Service Version Scan (-sV)

```
nmap -sV testphp.vulnweb.com
```

A terminal window titled 'akash@Akash: ~' showing the output of an Nmap service/version scan. The command executed is 'nmap -sV testphp.vulnweb.com'. The output indicates that the host is up, but all 1000 scanned ports are in ignored states due to no response. Service detection was performed but no results were identified.

```
(akash@Akash)-[~]
$ nmap -sV testphp.vulnweb.com
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-10-06 15:04 IST
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.0012s latency).
Other addresses for testphp.vulnweb.com (not scanned): 64:ff9b::2ce4:f903
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com
All 1000 scanned ports on testphp.vulnweb.com (44.228.249.3) are in ignored s
tates.
Not shown: 1000 filtered tcp ports (no-response)

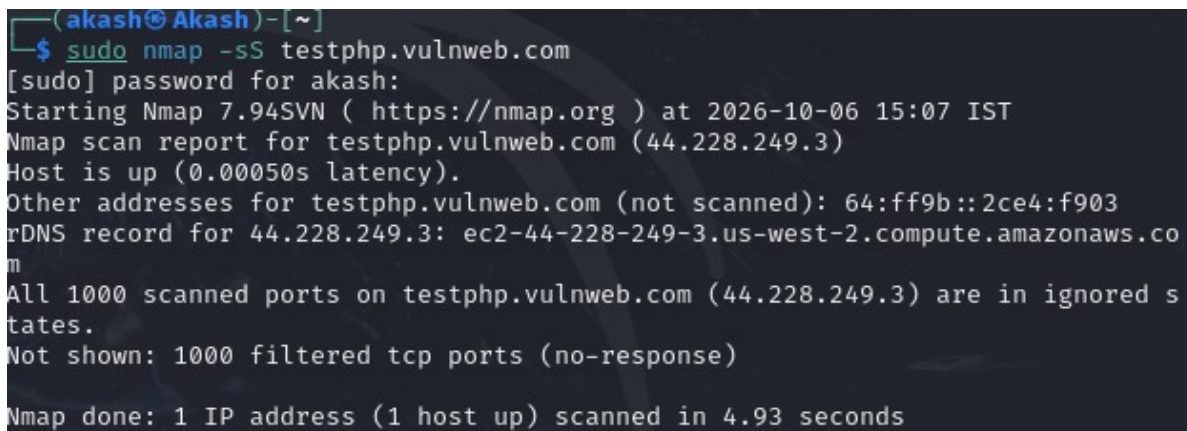
Service detection performed. Please report any incorrect results at https://n
map.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 5.92 seconds
```

Figure 1: Nmap service/version scan (-sV).

Result: the host resolved and was reported as up, but all 1000 default TCP ports were shown as filtered with no response. Because the ports did not respond, Nmap could not perform meaningful service/version identification.

2.2 SYN Scan (-sS)

```
sudo nmap -sS testphp.vulnweb.com
```

A terminal window showing the output of an Nmap SYN scan. The command executed is 'sudo nmap -sS testphp.vulnweb.com'. The output is identical to the service/version scan, showing that all 1000 scanned ports are filtered with no response.

```
(akash@Akash)-[~]
$ sudo nmap -sS testphp.vulnweb.com
[sudo] password for akash:
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-10-06 15:07 IST
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.00050s latency).
Other addresses for testphp.vulnweb.com (not scanned): 64:ff9b::2ce4:f903
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com
All 1000 scanned ports on testphp.vulnweb.com (44.228.249.3) are in ignored s
tates.
Not shown: 1000 filtered tcp ports (no-response)

Nmap done: 1 IP address (1 host up) scanned in 4.93 seconds
```

Figure 2: Nmap SYN scan (-sS).

The SYN scan produced the same core observation: 1000 filtered TCP ports and no confirmed open TCP port in the default scan set.

3. Nmap Aggressive Scan and Interpretation

```
sudo nmap -A testphp.vulnweb.com
```

```
└─$ sudo nmap -A testphp.vulnweb.com
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-10-06 15:09 IST
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.00050s latency).
Other addresses for testphp.vulnweb.com (not scanned): 64:ff9b::2ce4:f903
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com
All 1000 scanned ports on testphp.vulnweb.com (44.228.249.3) are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: firewall|router
Running: Cisco ASA 9.X, Synology embedded
OS CPE: cpe:/a:cisco:adaptive_security_appliance_software:9.2 cpe:/h:synology:rt1900ac
OS details: Cisco Adaptive Security Appliance (ASA 9.2), Synology RT1900ac router
Network Distance: 1 hop

TRACEROUTE (using port 80/tcp)
HOP RTT ADDRESS
1 0.34 ms ec2-44-228-249-3.us-west-2.compute.amazonaws.com (44.228.249.3)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 12.88 seconds
```

Figure 3: Nmap aggressive scan (-A).

The aggressive scan attempted additional OS detection and traceroute. Nmap explicitly warned that OS scan results might be unreliable because it could not find the combination of open and closed ports normally required for accurate fingerprinting.

3.1 Interpretation

- Host status: reachable according to Nmap.
- Port state: all 1000 scanned TCP ports were filtered/no-response.
- Service detection: inconclusive because no responsive open service was identified.
- OS fingerprint: not treated as confirmed because Nmap itself marked the result as unreliable.
- Traceroute information was produced, but it does not establish a vulnerability.

Security lesson: scan output must be interpreted carefully. A guessed device type or OS should not be reported as a confirmed vulnerability when the scanner warns that detection is unreliable.

4. Nikto - Web Vulnerability Scan

Nikto v2.5.0 was available in Kali Linux. The planned command was:

```
nikto -h http://testphp.vulnweb.com
```

A terminal window showing the output of the Nikto scan command. The prompt is a root shell on a Kali Linux machine. The command executed is 'nikto -h http://testphp.vulnweb.com'. The output shows 'Nikto v2.5.0', followed by a separator line, then '+ Multiple IPs found: 44.228.249.3, 64:ff9b::2ce4:f903', another separator line, and finally '+ 0 host(s) tested'.

```
$ nikto -h http://testphp.vulnweb.com
- Nikto v2.5.0

+ Multiple IPs found: 44.228.249.3, 64:ff9b::2ce4:f903

+ 0 host(s) tested
```

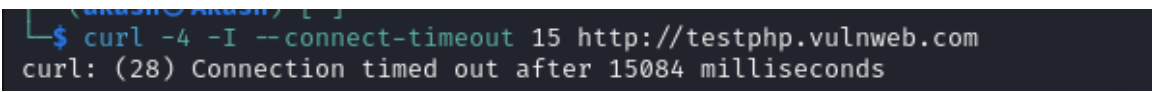
Figure 4: Nikto scan attempt showing 0 hosts tested.

Nikto resolved multiple addresses for the hostname but ended with '0 host(s) tested'. Therefore, no Nikto vulnerability finding is claimed in this report.

4.1 Connectivity Troubleshooting

To determine whether the issue was caused by Nikto itself or by network reachability, independent HTTP/TCP checks were performed.

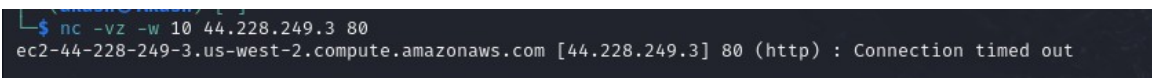
```
curl -4 -I --connect-timeout 15 http://testphp.vulnweb.com
```

A terminal window showing the output of a curl command. The prompt is a root shell on a Kali Linux machine. The command executed is 'curl -4 -I --connect-timeout 15 http://testphp.vulnweb.com'. The output is 'curl: (28) Connection timed out after 15084 milliseconds'.

```
$ curl -4 -I --connect-timeout 15 http://testphp.vulnweb.com
curl: (28) Connection timed out after 15084 milliseconds
```

Figure 5: IPv4 HTTP cURL request timing out.

```
nc -vz -w 10 44.228.249.3 80
```

A terminal window showing the output of a netcat command. The prompt is a root shell on a Kali Linux machine. The command executed is 'nc -vz -w 10 44.228.249.3 80'. The output shows the IP address 'ec2-44-228-249-3.us-west-2.compute.amazonaws.com' and the port '80 (http)', followed by ': Connection timed out'.

```
$ nc -vz -w 10 44.228.249.3 80
ec2-44-228-249-3.us-west-2.compute.amazonaws.com [44.228.249.3] 80 (http) : Connection timed out
```

Figure 6: Netcat TCP port 80 connectivity test timing out.

Conclusion: the target's HTTP service was not reachable from the current network path during testing. This is consistent with the Nmap filtered/no-response result and explains why Nikto could not complete a web-server scan.

5. Burp Suite - Proxy Setup

Burp Suite Community Edition was launched in Kali Linux using a temporary in-memory project and the default Burp configuration. The built-in browser was used so that proxy configuration could be handled automatically.

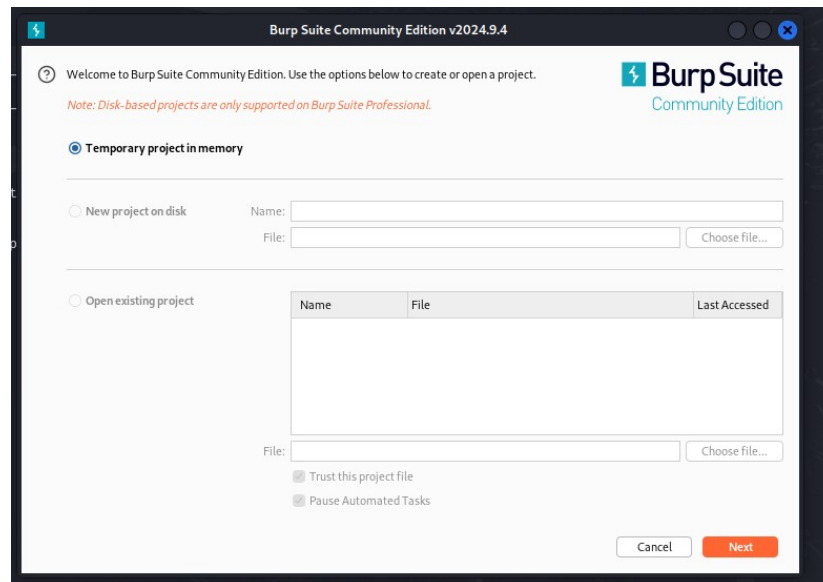


Figure 7: Burp Suite temporary project selection.

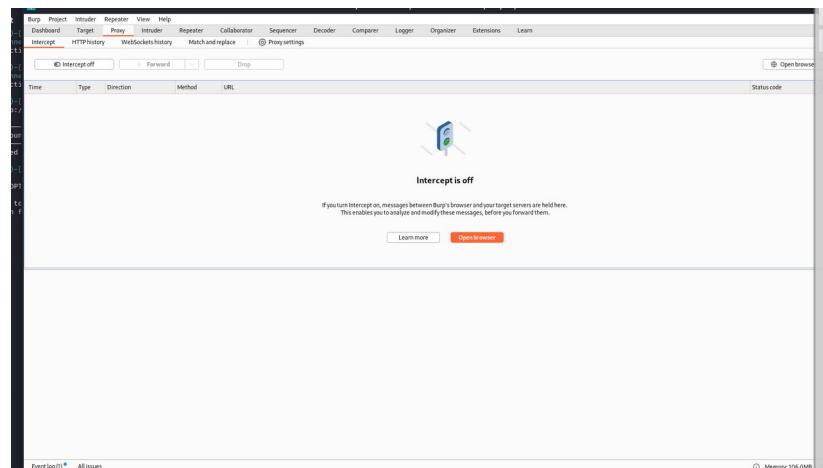


Figure 8: Proxy > Intercept interface before request capture.

Intercept was enabled and the Burp browser was opened. This allowed requests generated by the browser to be held and inspected before being forwarded.

5.1 What Interception Demonstrates

- HTTP method and requested path can be inspected.
- Host and browser-related request headers are visible to the proxy.
- Requests can be paused before being forwarded.
- Security testers can study request structure without modifying the target application.

6. Burp Suite - Captured Request 1

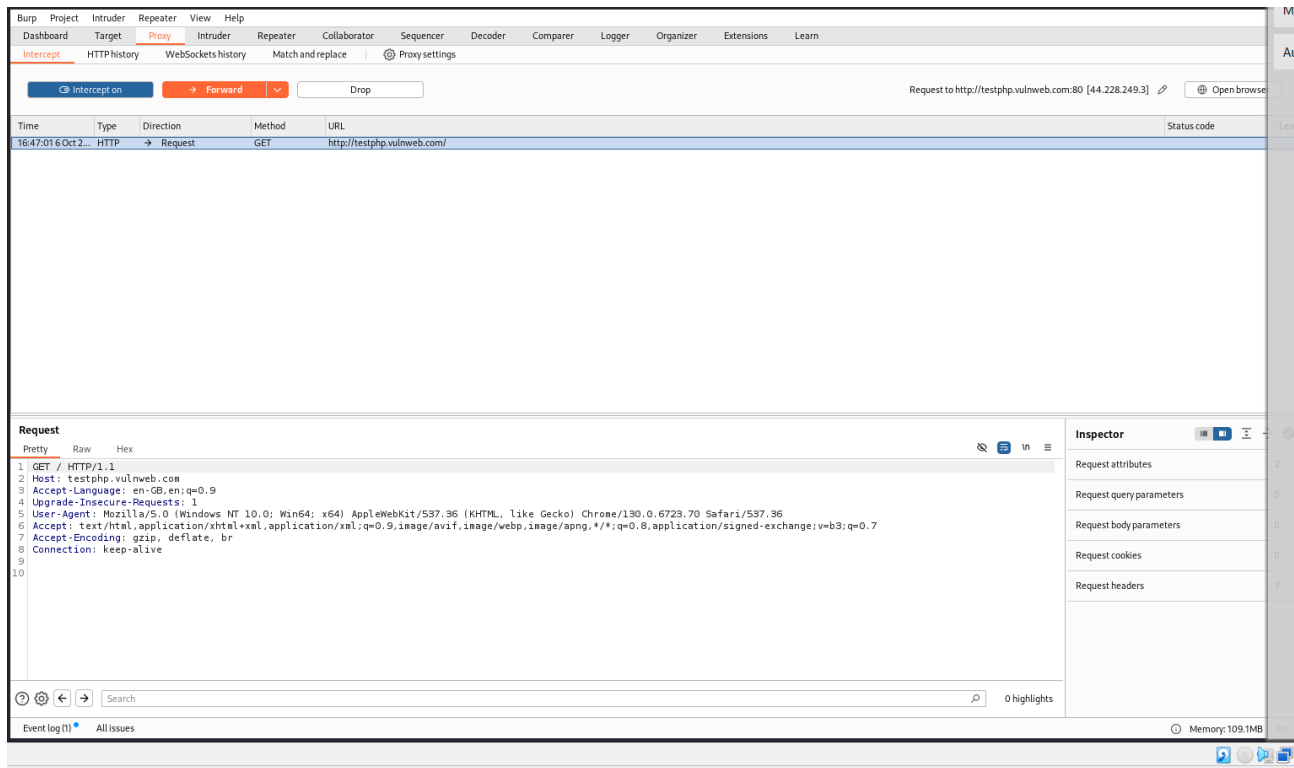


Figure 9: Intercepted GET request for the root path (/).

The first request was successfully intercepted before forwarding. The request used the GET method and targeted the root path of the authorized test host.

6.1 Important Request Elements

- GET / HTTP/1.1 - requests the root resource.
- Host: testphp.vulnweb.com - identifies the destination virtual host.
- User-Agent - identifies browser/client characteristics.
- Accept and Accept-Encoding - describe content formats and encodings the browser can handle.
- Connection: keep-alive - requests reuse of the TCP connection when possible.

This screenshot proves that Burp Suite was functioning as an intercepting proxy even though the remote server response was unavailable during the test window.

7. Burp Suite - Captured Requests 2 and 3

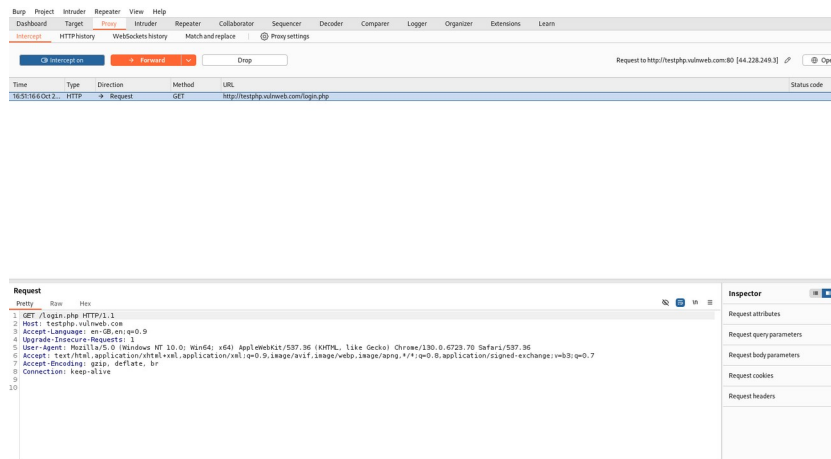


Figure 10: Intercepted GET request for /login.php.

A second request was generated for /login.php. Burp captured the request and displayed its headers for inspection.

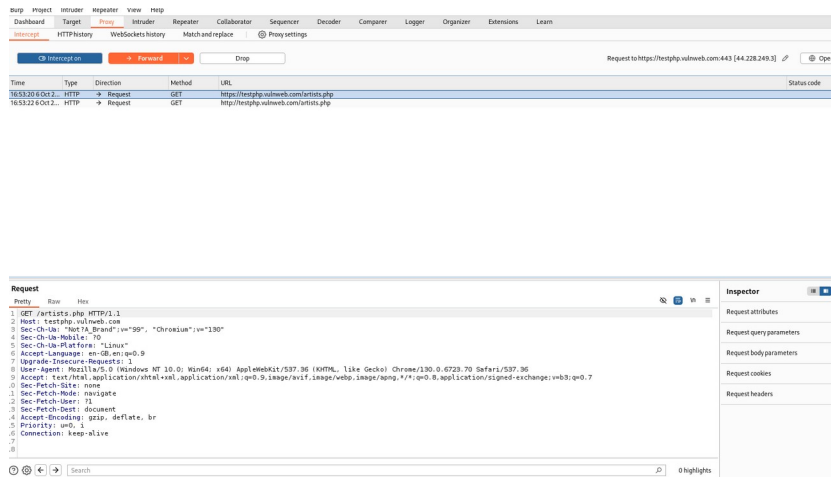


Figure 11: Intercepted request for /artists.php.

A third request was generated for /artists.php. Burp showed both HTTP/HTTPS request entries during testing and displayed the request headers in the lower panel.

7.1 Burp Practical Status

- Request 1: GET / - captured.
- Request 2: GET /login.php - captured.
- Request 3: GET /artists.php - captured.
- Headers inspected: Host, User-Agent, Accept, Accept-Encoding, Sec-Fetch fields and connection information.

8. Findings and Observations

The internship mini-task asks for at least three issues/findings. Because the target did not return normal service responses during this test window, the following are reported as evidence-based observations rather than fabricated vulnerabilities.

Finding 1 - TCP Ports Appeared Filtered

Nmap reported all 1000 default scanned TCP ports as filtered/no-response. This indicates that probes were not receiving normal TCP responses. Possible causes include filtering, firewall rules, upstream controls, or temporary target/network conditions. It is not sufficient evidence by itself to claim a vulnerability.

Finding 2 - Web Service Was Unreachable During Nikto Testing

Nikto reported 0 hosts tested. Independent cURL and Netcat checks to the HTTP service timed out. Therefore, the web vulnerability scan could not be completed from the current network path. This limitation was documented rather than replaced with assumed Nikto findings.

Finding 3 - HTTP Request Metadata Was Observable Through the Proxy

Burp Suite successfully intercepted multiple requests and exposed request paths and client headers such as Host, User-Agent, Accept and encoding information. This is expected behavior for an intercepting proxy and demonstrates why HTTPS, secure session handling, and careful header/cookie management are important. The observation itself is not presented as a vulnerability.

8.1 Risk Interpretation

No confirmed exploitable vulnerability was established from the available scan evidence. The exercise primarily demonstrated reconnaissance, connectivity analysis, proxy interception, and the importance of distinguishing scanner observations from validated security weaknesses.

9. Conclusion

Week 5 introduced practical VAPT tooling using Nmap, Nikto and Burp Suite. Nmap scans were completed and showed that the target was reachable while the default TCP ports appeared filtered. Nikto was correctly installed and executed, but the authorized web target could not be reached over HTTP from the current network path; cURL and Netcat confirmed the timeout. Burp Suite was successfully configured and used to intercept three HTTP requests, allowing inspection of methods, paths and request headers.

The most important learning from this task was that security testing is not only about running commands. Results must be validated, limitations must be documented, and unconfirmed scanner output must not be reported as a vulnerability.

9.1 Learning Outcomes

- Understood the purpose and differences of Nmap -sS, -sV and -A scans.
- Learned how filtered ports affect service and OS detection.
- Learned how to troubleshoot a failed Nikto scan using cURL and Netcat.
- Configured Burp Suite and captured three web requests.
- Practiced interpreting HTTP headers and request structure.
- Learned to report only evidence-supported findings in a VAPT report.

10. Ethical Testing Statement

All testing documented in this assignment was performed only against the internship-provided authorized test target. No unauthorized real-world website was tested.

11. Final Task Status

Task	Status
Nmap network scanning	Completed
Nikto web scan	Attempted; target HTTP connectivity unavailable
Burp Suite request interception	Completed - 3 requests captured
Evidence/screenshots	Completed
Findings and interpretation	Completed